

Chain Pwn

Bối cảnh (Context)

Công ty WebCloud có một hệ thống máy chủ rất vững chắc bảo vệ bằng Firewall. Chỉ có một chức năng duy nhất được mở ra bên ngoài là "Preview Website" - cho phép người dùng nhập URL để máy chủ chụp ảnh trang web đó.

Bên trong mạng nội bộ, có một ứng dụng Redis Server không cần mật khẩu đang chạy (vì Dev cho rằng không ai ngoài mạng có thể vào được tới đó).

Mục tiêu (Objective)

- **Nhiệm vụ:** Xây dựng một chuỗi khai thác. Mượn tay máy chủ bên ngoài để kết nối với máy chủ Redis bên trong, từ đó thực thi mã độc lấy Flag.
- **Vấn đề / Lỗ hổng: Exploit Chain: SSRF to RCE.** Chức năng Preview dính lỗi Server-Side Request Forgery (SSRF), cho phép bạn điều hướng máy chủ tạo request đến `localhost` hoặc mạng nội bộ. Máy chủ Redis bên trong mạng nội bộ có thể bị thao túng qua giao thức `gopher://` hoặc `dict://` để ghi một file cấu hình hoặc SSH key, dẫn đến chiếm quyền máy chủ.
- **Flag:** Root được hệ thống nội bộ.

Gợi ý (Hints)

- Thử nhập địa chỉ URL là `http://127.0.0.1:6379` xem máy chủ có phản hồi điều gì từ cổng của Redis không.
- Tìm hiểu về công cụ Gopherus để sinh payload khai thác Redis qua SSRF.